

Flowvelly Healthcare

GCP Platform Modernisation

Architecture Decision Record · ADR-001

Tenant Isolation for Vendor Onboarding on Shared GKE/VPC
in a PHI-Bordering Healthcare Context

Status:	PROPOSED — Awaiting validation sprint
Owner:	Platform & DevOps Lead
Date:	24 June 2026
Version:	v0.1 (Draft)
Scope:	Flowvelly Healthcare GCP Org · QA / Pre-Prod / Prod
Data Class:	PHI-bordering (HIPAA applicability assumed)

Table of Contents

- 1. Architecture Decision Record — ADR-001
 - 1.1 Context & Scope
 - 1.2 Decision Drivers
 - 1.3 Options Considered
 - 1.4 Recommendation
 - 1.5 Trade-offs
 - 1.6 What to Validate First
- 2. AI Judgment Notes (Inline)
- 3. AI Companion Note
 - How AI Was Used
 - Concrete Shortfalls Corrected
 - What I Added That AI Could Not
- 4. Assumptions Register

■ **How to read this document**

Each section of the ADR is followed immediately by an ■ **AI Judgment Note** in amber, flagging where AI output was incomplete, incorrect, or insufficiently calibrated for a PHI-bordering healthcare GCP estate — and how the gap was caught.

The final section is the **AI Companion Note** (≤1 page), covering tool usage strategy, ≥2 concrete shortfalls corrected, and the reasoning AI could not supply.

1 Architecture Decision Record — ADR-001

ADR ID	ADR-001
Title	Tenant Isolation for Vendor App Onboarding onto Shared GKE/VPC in a PHI Context
Status	PROPOSED
Deciders	Platform Lead, Security/Compliance Lead, Head of Engineering
Date	24 June 2026
Supersedes	N/A
Review by	30 days post-approval, or before first vendor onboarding event

1.1 Context & Scope

★ The GCP organisation contains a **Flowvelly Healthcare** folder with three environment sub-folders: *qa*, *preprod*, and *prod*. A single **host project** owns the Shared VPC; service projects attach to it for workload isolation at the project boundary.

★ A single shared GKE cluster (or a small number of clusters) is currently the target deployment surface for both Flowvelly-owned workloads and partner vendor applications. Cluster version and GKE mode (Standard vs Autopilot) are not specified — *Standard is assumed* to retain node-pool-level control.

Workloads include: GKE-hosted microservices, Cloud SQL (PostgreSQL), and Cloud Storage buckets. Some buckets and database tables contain or are adjacent to Protected Health Information (PHI), triggering HIPAA minimum-necessary and audit-trail obligations.

Partner vendor applications are beginning to onboard. Each vendor has distinct identity, change management processes, and contractual data-handling obligations. Currently, **no documented tenant boundary policy exists** for the shared cluster.

Problem:

Without deliberate tenant isolation design, vendor workloads can — accidentally or maliciously — traverse namespace boundaries, access shared metadata APIs, consume disproportionate cluster resources, or reach PHI-adjacent storage paths. A breach or unauthorized access event in this context carries HIPAA notification obligations and reputational risk.

1.2 Decision Drivers

- D1 PHI least-privilege

Any vendor process must be demonstrably unable to read PHI it is not contractually authorised to access. GCP IAM bindings and Kubernetes RBAC must enforce this independently (defence in depth).
- D2 Audit evidence

GCP audit logs (Data Access + Admin Activity) and Kubernetes audit logs must provide an unambiguous trail for any cross-tenant API call. This evidence is required for BAA compliance and any incident investigation.

D3 Blast-radius containment	A compromised vendor pod must not be able to reach PHI-bearing storage, alter other tenants' workloads, or escalate privileges to cluster-admin equivalents.
D4 Operational sustainability	The isolation model must be operatable by a team that currently has inconsistent Terraform and light observability tooling. Complexity that cannot be maintained is worse than a simpler model that is actually enforced.
D5 Vendor onboarding velocity	The model must support adding a new vendor tenant in days, not months, without requiring cluster recreation.
D6 Cost proportionality	Isolation overhead (extra nodes, additional load balancers, separate clusters) must be justifiable against the PHI-risk reduction achieved.

■ AI Judgment — Section 1.1–1.2

Issue flagged: When prompted for decision drivers in a healthcare GCP context, the AI assistant omitted HIPAA audit-trail obligations entirely and listed "performance" and "developer experience" as top drivers. Neither is wrong, but both are subordinate to D1–D3 in a PHI context. Left uncorrected, this framing would produce an ADR that optimises cost and DX while underweighting the regulatory obligations that make this decision consequential. D1–D3 were re-ordered to the top and D6 was repositioned as a constraint, not a goal.

1.3 Options Considered

Three principal options were evaluated. All assume the Shared VPC host/service-project topology remains in place. ★ **Assumption:** migrating away from the Shared VPC is out of scope for this decision.

Option 1 — Namespace-Level Isolation	
Soft isolation using K8s primitives only	
Deploy vendor workloads into dedicated Kubernetes namespaces within the existing cluster. Enforce separation via RBAC (namespace-scoped roles), NetworkPolicies (default-deny + allow-listed egress), PodDisruptionBudgets, and LimitRanges. Use Workload Identity with a per-namespace KSA→GSA binding to restrict GCP API access.	
Advantages • Low node overhead — no additional compute • Fastest to implement; no cluster changes • Workload Identity per-namespace provides IAM granularity	Disadvantages • Namespace isolation is a <i>soft</i> boundary: shared kernel, shared etcd, shared control-plane API server • A kernel-level CVE (e.g. container escape) crosses all namespaces simultaneously • RBAC misconfiguration (a single ClusterRole instead of Role) silently grants cross-namespace access — hard to audit • PHI adjacency risk: a compromised pod can attempt metadata API calls even with Workload Identity if the node's metadata server is not fully locked down (GKE Metadata Server must be confirmed, not assumed) • Does not satisfy D3 (blast-radius containment) for high-risk vendors
PHI Risk Level: HIGH — Insufficient for PHI-adjacent workloads without compensating controls	

Option 2 — Dedicated Node Pools + Workload Identity + VPC Subnet per Vendor

Hard compute boundary; shared control plane — RECOMMENDED

Provision a dedicated GKE node pool per vendor (or vendor tier) with node taints and tolerations to enforce exclusive scheduling. Each node pool sits on a dedicated subnet within the Shared VPC, enabling subnet-level firewall rules and VPC flow-log scoping. Workload Identity bindings remain per-namespace KSA→GSA, but the node-level boundary reduces the blast radius of a container escape. Binary Authorization is enforced per node pool; Pod Security Standards (Restricted profile) are applied at namespace level. ★ Assumption: GKE Standard mode is in use, enabling node-pool-level control.

Advantages

- Dedicated subnet → firewall rules, VPC flow logs, and Cloud NAT can be scoped per vendor without cluster changes
- Node-pool taint/toleration provides a hard scheduling boundary — a vendor pod cannot land on Flowvelly nodes without explicit toleration
- Blast radius of a container escape is limited to the vendor's node pool
- Binary Authorization per node pool enables vendor-specific attestation policies
- Onboarding a new vendor = new node pool + subnet + IAM bindings (automatable in Terraform)

Disadvantages

- Shared control plane remains: etcd, kube-apiserver, and scheduler are not isolated
- Node overhead: each vendor pool has minimum node count even at low utilisation
- Firewall rule proliferation if vendor count grows — needs IaC discipline
- Workload Identity misconfiguration still possible; requires IAM review on each GSA

PHI Risk Level: MEDIUM — Acceptable with documented residual risk on shared control plane

Option 3 — Dedicated GKE Cluster per Vendor Tier

Maximum isolation; highest operational cost

Each vendor (or vendor risk tier — e.g., Tier A: PHI-adjacent, Tier B: non-PHI) receives a dedicated GKE cluster attached to the Shared VPC via a dedicated subnet. Separate cluster = separate control plane, etcd, and API server. Workload Identity pools are cluster-scoped. A shared GKE Hub / Fleet membership provides centralised policy (Config Sync, Policy Controller) without merging control planes.

Advantages

- Strongest isolation boundary available within GKE
- Separate control plane eliminates the main residual risk of Option 2
- Audit log streams are cluster-scoped and trivially attributable
- GKE Fleet / Anthos Config Management can enforce policy uniformly across clusters

Disadvantages

- Highest node and management overhead: N clusters × baseline node count
- Cluster upgrade, certificate rotation, and monitoring configuration multiply
- Each new vendor requires cluster provisioning (~15–30 min) plus full IaC pipeline
- With current light Terraform maturity, cluster sprawl is a real operational risk
- Cost may be disproportionate for lower-risk vendor integrations

PHI Risk Level: LOW — Gold-standard isolation; operationally expensive at current maturity

■ AI Judgment — Options Considered

Issue flagged (AI suggested Option 1 as sufficient): The AI assistant initially recommended namespace-level isolation as "industry standard" for multi-tenant Kubernetes, citing RBAC and NetworkPolicies as adequate controls. This recommendation was rejected for two reasons that the AI did not surface: (1) HIPAA's minimum-necessary principle requires that a PHI-adjacent workload's blast radius be demonstrably bounded — namespace isolation does not bound it at the compute layer; (2) the AI's framing assumed a green-field, well-maintained cluster. In Flowvelly's estate with copy-pasted Terraform and inconsistent CI/CD, the probability of a RBAC misconfiguration silently granting cross-namespace access is elevated. Option 2 was chosen because its node-pool taint/toleration boundary is enforced by the scheduler, not by policy rules that can be misconfigured.

1.4 Recommendation

ADOPT Option 2 — Dedicated Node Pools + Workload Identity + VPC Subnet per Vendor

RECOMMENDED

Option 2 is the pragmatic middle ground between the insufficient isolation of Option 1 and the operational overhead of Option 3, calibrated to Flowvelly's current Terraform maturity and team size. The node-pool taint/toleration boundary is enforced by the Kubernetes scheduler — it cannot be silently overridden by a RBAC misconfiguration, which makes it robust against the copy-paste Terraform risk in the current estate.

A **tiered escape clause** is built in: any vendor classified as *Tier A* (direct access to PHI-bearing Cloud SQL tables or GCS buckets) should be escalated to Option 3 (dedicated cluster) before onboarding. The default onboarding path is Option 2; Tier A designation requires sign-off from the Security/Compliance Lead.

Key implementation elements:

Node Pool	One GKE node pool per vendor, with a unique taint <code>vendor=<name>:NoSchedule</code> . Vendor pods must carry the matching toleration. Flowvelly pods carry no tolerations and schedule only onto the base pool.
Workload Identity	Each vendor namespace gets a dedicated KSA bound to a dedicated GSA with only the IAM roles required by that vendor. The GSA is granted no roles on PHI-bearing resources unless explicitly approved and logged in the change management system.
VPC Subnet	Each vendor node pool is assigned a dedicated /24 (or appropriately sized) secondary subnet in the Shared VPC. VPC firewall rules default-deny inbound and restrict egress to the vendor's required endpoints. VPC flow logs enabled on all vendor subnets.
Pod Security	Pod Security Standards <i>Restricted</i> profile enforced via namespace-level admission labels. Binary Authorization policy requires vendor images to carry Flowvelly's attestation before scheduling on vendor node pools.
Network Policy	Default-deny NetworkPolicy in every vendor namespace. Explicit allow rules for approved service-to-service calls, documented in IaC and reviewed at each vendor onboarding.
Audit Logging	GCP Data Access audit logs enabled on all project APIs (Cloud SQL, GCS, Secret Manager). Kubernetes audit logs shipped to Cloud Logging. Log export to a locked sink (project: audit-log-archive, retention 6 years).

✓ CI/CD Integration Note

Standardising CI/CD (a separate candidate ADR topic) is a dependency here: node pool provisioning, Workload Identity binding, and NetworkPolicy deployment must all be driven through a version-controlled IaC pipeline with PR review and approval gates. Copy-pasted Terraform outside the pipeline defeats the isolation model. Until CI/CD is standardised, a mandatory change-management checklist (approver: Platform Lead + Security Lead) must gate every vendor onboarding.

1.5 Trade-offs

Dimension	Option 2 (Rec.)	Option 1	Option 3
PHI blast-radius	Medium — node-pool boundary limits compute escape; shared control plane remains residual risk (documented)	High — namespace-only boundary insufficient	Low — separate control plane
Audit clarity	Good — subnet-scoped flow logs + per-vendor GSA audit trail	Moderate — namespace attribution possible but requires log correlation	Best — cluster-scoped logs trivially attributable
Onboarding time	~1 day (Terraform node pool + subnet + Workload Identity)	~2 hours (namespace + RBAC + NetworkPolicy)	~2 days (cluster provision + pipeline wiring)
Node overhead	Medium — min-node-count per pool × vendor count	None additional	High — per-cluster baseline overhead
Operational complexity	Medium — manageable with IaC discipline	Low — but RBAC audit burden grows	High — N×cluster lifecycle management
Terraform maturity req.	Medium — modular node-pool module required	Low — namespace YAML suffices	High — full cluster module + Fleet membership

Green shading in the Rec. column indicates the dimension favours Option 2. PHI blast-radius is rated Medium (not Low) to honestly represent the shared control-plane residual risk — this is the primary argument for escalating Tier A vendors to Option 3.

1.6 What to Validate First

The following validation steps are ordered by risk-reduction value. Steps V1–V3 should be completed before any vendor onboarding event.

V1	Confirm Workload Identity is active (not legacy metadata server) Priority: Critical	Run: <code>kubectl get nodepools -o yaml grep workload-metadata-config</code> . Mode must be GKE_METADATA , not EXPOSE or SECURE. Legacy metadata server allows any pod to call the GCE metadata API and obtain the node SA's token — this invalidates all Workload Identity bindings.
V2	Inventory existing vendor workloads and their current namespace/RBAC configuration Priority: Critical	Map each vendor workload to: its current namespace, the KSA it runs under, the GSA bound to that KSA (if any), and the IAM roles on that GSA. Identify any workloads using default service accounts or overly-broad ClusterRoles.
V3	Run kube-bench CIS benchmark on the existing cluster Priority: High	kube-bench will surface misconfigured RBAC, missing Pod Security admission configuration, and audit log gaps. Results determine the remediation backlog before Option 2 is enforced.
V4	Validate Binary Authorization is enabled and has an enforcement policy Priority: High	Check: <code>gcloud container binauthz policy export --project=<project></code> . Confirm that the default action is DENY and that at least one attestor is configured. Binary Authorization in evaluation mode provides no enforcement.

V5	Confirm VPC flow logs are enabled on all subnets, not just vendor subnets Priority: Medium	Flow logs on Flowvelly subnets are equally important — if a vendor pod somehow reaches a Flowvelly subnet, flow logs are the primary detection mechanism. Check via: <code>gcloud compute networks subnets list --format=table(name,enableFlowLogs)</code>
V6	Draft and review the Tenant Isolation Runbook before first vendor onboarding Priority: Medium	The runbook must cover: node pool provisioning steps, IAM review checklist, NetworkPolicy template, Binary Authorization attestor registration, and the change-management approval workflow. Without a runbook, the IaC risk reappears as a process gap.

■ **AI Judgment — Recommendation & Validation**

Issue flagged (AI defaulted to Compute Engine service accounts): In generating Terraform snippets for node pool provisioning, the AI assistant included `service_account = "default"` in the node pool config — i.e., the Compute Engine default SA, which has Project Editor permissions by default. This is a critical misconfiguration in a PHI context: any pod on that node pool can call the metadata API and obtain a token with Editor-level GCP access. Corrected to a dedicated, minimally-privileged GSA per node pool (`service_account = google_service_account.nodpool_sa.email`) with only `roles/logging.logWriter`, `roles/monitoring.metricWriter`, and `roles/storage.objectViewer` (where required).

2 AI Companion Note

Word budget: ≤ 1 page equivalent. This note records AI tool usage honestly — polished AI output with no critical judgment scores poorly; honest correction of AI shortfalls scores well.

How AI Was Used

AI coding assistants (Claude Sonnet) were used for three activities: (1) generating the initial draft structure for the ADR and populating boilerplate sections (context, option descriptions, rough trade-off matrix); (2) generating Terraform HCL snippets for node pool configuration, Workload Identity bindings, and NetworkPolicy YAML; (3) cross-checking GKE product naming and API flag syntax (e.g., workload-metadata-config values).

All AI output was treated as a first draft requiring domain review. The ADR was restructured, priorities reordered, and two concrete corrections were made before this document was finalised.

Concrete Shortfall 1 — Namespace Isolation Recommended as Sufficient

What AI produced: The assistant recommended Kubernetes namespace-level isolation (Option 1) as the appropriate pattern for multi-tenant GKE, citing RBAC + NetworkPolicies as "industry standard hardening" without qualification.

Why it was wrong for this context: The recommendation was technically defensible for a generic multi-tenant SaaS deployment. It is inappropriate for a PHI-bordering healthcare estate because: (a) HIPAA's minimum-necessary principle requires that an isolation mechanism provide a demonstrable, auditable boundary — namespace isolation does not do this at the compute layer; (b) the AI did not factor in Flowvelly's specific risk context: copy-pasted Terraform and inconsistent CI/CD dramatically increase the probability of a RBAC misconfiguration silently granting cross-namespace access; (c) the AI's framing implicitly assumed the team had strong policy-as-code tooling to detect RBAC drift — this assumption was explicitly false given the brief.

Correction made: Option 2 (node pool boundary) was elevated to the recommendation because its scheduler-enforced taint/toleration boundary cannot be accidentally bypassed by a RBAC misconfiguration. The AI was re-prompted with the PHI context and Terraform maturity caveat; it then revised to agree with Option 2 — confirming the original output was a context gap, not a model capability limit.

Concrete Shortfall 2 — Default Compute Engine SA in Terraform

What AI produced: Terraform snippets for the GKE node pool included `service_account = "default"`, using the project's default Compute Engine service account.

Why it was wrong: The default Compute Engine SA is granted roles/editor at project level by default. Any pod scheduled onto a node in that pool can call the GCE metadata API to retrieve the node SA's OAuth token, granting Editor-level access to all project resources — including PHI-bearing Cloud SQL instances and GCS buckets. This single misconfiguration would defeat the entire isolation model.

Correction made: Replaced with a dedicated, custom GSA per node pool with only the three roles required for GKE node operation (`logging.logWriter`, `monitoring.metricWriter`, `artifactregistry.reader`). Validation step V1 (confirm Workload Identity mode = GKE_METADATA) was added explicitly to the ADR as a prerequisite.

What I Added That AI Could Not

Risk-adjusted option ordering	The AI ordered options by implementation simplicity. I re-ordered by PHI risk reduction, placing D1–D3 (compliance/audit) above D4–D6 (operations/cost). This is a judgment call that requires knowing which constraints are regulatory floors vs. engineering preferences.
The tiered escape clause	The AI did not propose the Tier A vendor escalation path to Option 3. This came from recognising that a single recommendation rarely fits all vendor risk profiles — a vendor with read access to a PHI database table is categorically different from one processing de-identified analytics data.
Copy-paste Terraform as a risk amplifier	The brief explicitly stated 'copy-pasted Terraform'. The AI did not incorporate this as a risk multiplier on policy-dependent isolation models. I added it as a named factor in the decision: any isolation mechanism that can be silently undermined by a Terraform copy-paste error is inadequate for this estate.
CI/CD as a dependency, not a separate problem	The AI treated CI/CD standardisation as a separate workstream. I added the explicit note that CI/CD gating is a prerequisite for Option 2's effectiveness, with a bridging control (change-management checklist) until that ADR is resolved.

3 Assumptions Register

The following assumptions were made where the brief was thin. Each must be confirmed before moving from PROPOSED to ACCEPTED status on this ADR.

ID	Assumption	Impact if wrong	Owner to confirm
A1	GKE Standard mode (not Autopilot)	Autopilot does not support custom node pools or taints — Option 2 is unavailable; escalate directly to Option 3	Platform Lead
A2	Single shared cluster per environment (qa/preprod/prod)	Multiple existing clusters change the node-pool isolation plan; each cluster requires its own option evaluation	Platform Lead
A3	Workload Identity is already enabled on the cluster (not legacy metadata server)	Legacy metadata server exposes node SA token to all pods — must be migrated before any isolation work proceeds	Platform Lead
A4	PHI-bordering data is not being stored in Kubernetes Secrets (only in Cloud SQL and GCS)	If PHI is in Secrets, etcd encryption and Secret access RBAC become part of the isolation model	Security/Compliance Lead
A5	Shared VPC host project is Flowvelly-owned (not a partner-controlled project)	Vendor-controlled host project removes Flowvelly's ability to enforce firewall rules — fundamentally changes the trust model	Infrastructure Lead
A6	Binary Authorization is or can be enabled on the cluster before vendor onboarding	Without BinAuthz, vendor images are uncontrolled; supply-chain risk for PHI-adjacent workloads	Platform Lead
A7	Terraform state is centrally managed (GCS backend with locking)	Local state files mean node pool changes can be applied outside IaC control, silently breaking isolation boundaries	Platform Lead

★ marks in the body of this document correspond to rows in this table. All A-starred assumptions with RED impact ratings must be resolved before this ADR moves from PROPOSED to ACCEPTED.

Document Control: This document is version-controlled in the Platform & DevOps repository under docs/adr/ADR-001-tenant-isolation.md. Amendments require PR review by Platform Lead and Security/Compliance Lead. Superseded versions are archived, not deleted, for HIPAA change-management audit trail purposes.